

Sec 8.4. Burp Suite Basics

Task 1 - Introduction

The core of the Burp Suite framework is the Burp Proxy.

Task 2 - What is Burp Suite

Burp Suite is a Java-based framework designed to serve as a comprehensive solution for conducting web application penetration testing. It has become the industry standard tool for hands-on security assessments of web and mobile applications, including those that rely on application programming interfaces (APIs). Burp Suite captures and enables manipulation of all the HTTP/HTTPS traffic between a browser and a web server. This fundamental capability forms the backbone of the framework. By intercepting requests, users have the flexibility to route them to various components within the Burp Suite framework, which we will explore in upcoming sections. The ability to intercept, view, and modify web requests before they reach the target server or even manipulate responses before they are received by our browser makes Burp Suite an invaluable tool for manual web application testing.

Which edition of Burp Suite runs on a server and provides constant scanning for target web apps? Burp Suite Enterprise

Burp Suite is frequently used when attacking web applications and applications. Mobile

Task 3 - Features of Burp Community

Proxy: allows us to intercept and modify requests/responses when interacting with web applications.

Repeater: allows us to capture, modify, then resend the same request numerous times.

Intruder: allows us to spray an endpoint with requests. This is often used for bruteforce attacks or to fuzz endpoints.

Decoder: allows us to decode captured information, or encode a payload prior to sending it to the target.

Comparer: allows us to compare two pieces of data at either word or byte level.

Sequencer: allows us to assess the randomness of tokens such as session cookie values or other supposedly random generated data. If the algorithm is not generating secure random values, then this could open up some devastating avenues for attack.

Which Burp Suite feature allows us to intercept requests between ourselves and the target? Proxy

Which Burp tool would we use to brute-force a login form? Intruder

Task 4 - Installation

Install Burp Suite using the appropriate method for your operating system.

Task 5 - The Dashboard

After opening Burp Suite Community and opening a new project you are met by the Burp Dashboard.



In short, the Dashboard interface is split into four quadrants:

1. The Tasks menu allows us to define background tasks that Burp Suite will run whilst we use the application.
2. The Event log tells us what Burp Suite is doing (e.g. starting the Proxy), as well as information about any connections that we are making through Burp.
3. The Issue Activity section is exclusive to Burp Pro. It won't give us anything using Burp Community, but in Burp Professional it would list all of the vulnerabilities found by the automated scanner.
4. The Advisory section gives more information about the vulnerabilities found, as well as references and suggested remediations. These could then be exported into a report.

Task 6 - Navigation

Navigating around the Burp Suite GUI by default is done entirely using the top menu bars. These allow you to switch between modules. If the selected module has more than one sub-tab, then these can be selected using a second menu bar which appears directly below the original bar. Ctrl + Shift + D Switch to the Dashboard Ctrl + Shift + T Switch to the Target tab Ctrl + Shift + P Switch to the Proxy tab Ctrl + Shift + I Switch to the Intruder tab Ctrl + Shift + R Switch to the Repeater tab.

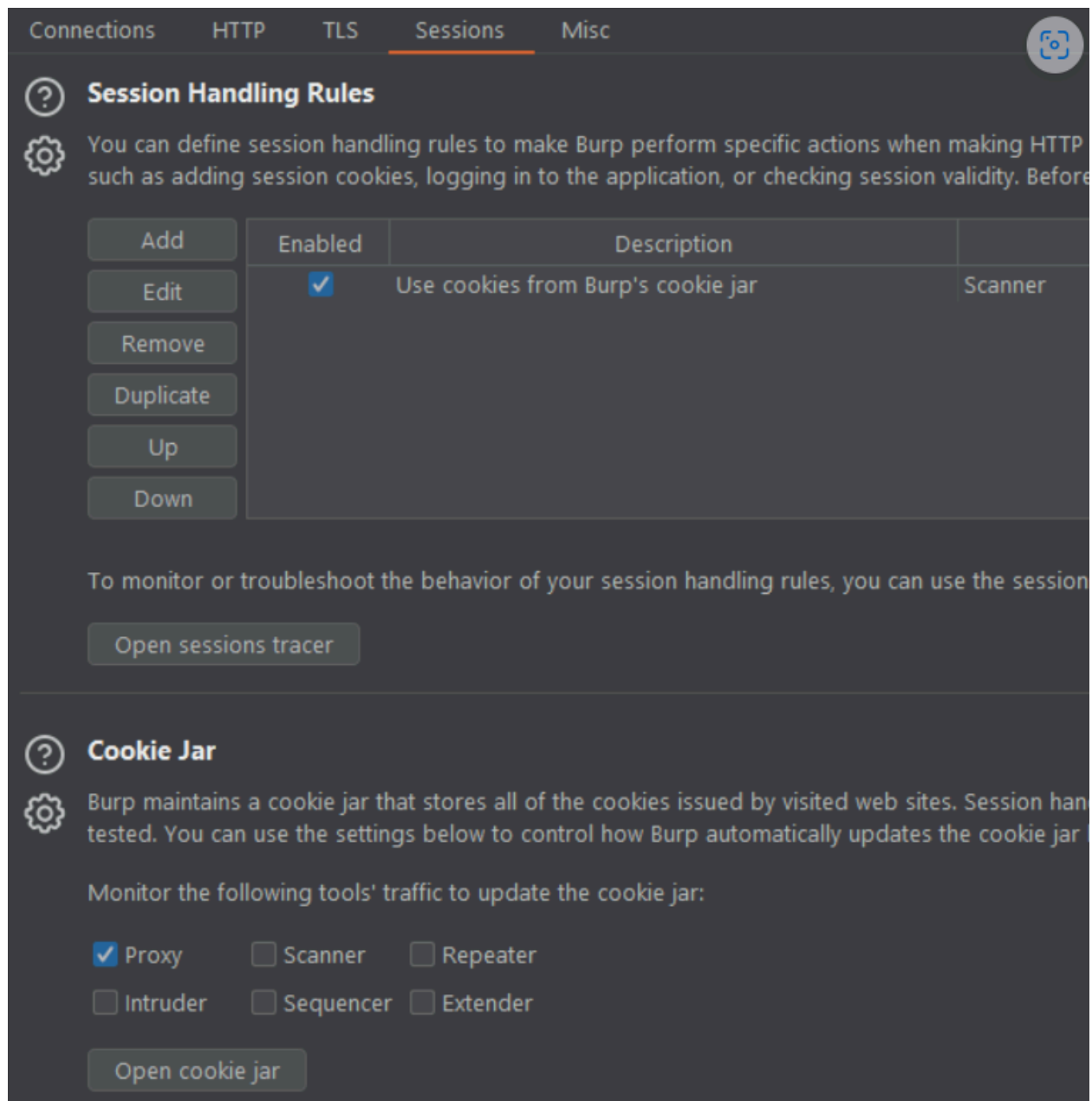
Task 7 - Options

There are two type of settings available for configuring Burp Suite.

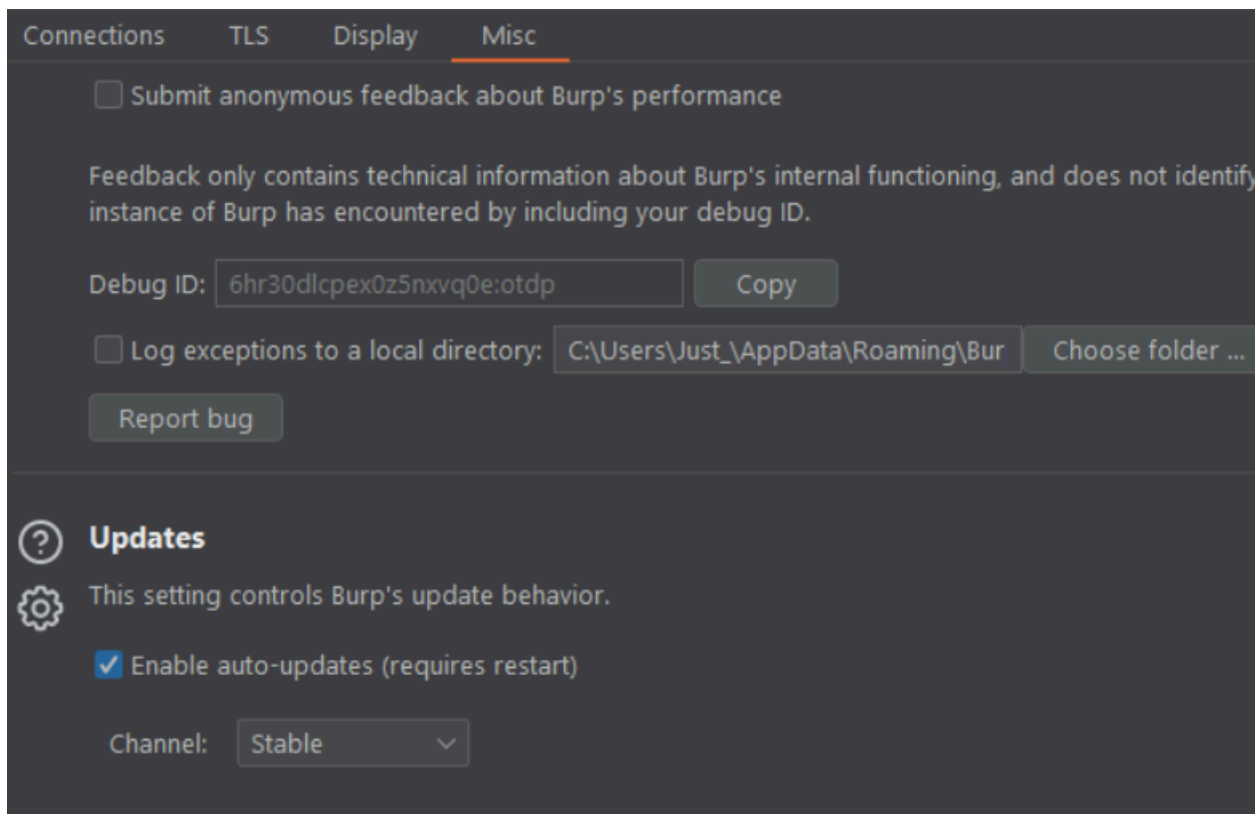
1. Global settings can be found in the User options tab along the top menu bar.
2. Project-specific settings can be found in the Project options tab.

| In which category can you find a reference to a "Cookie jar"? Sessions

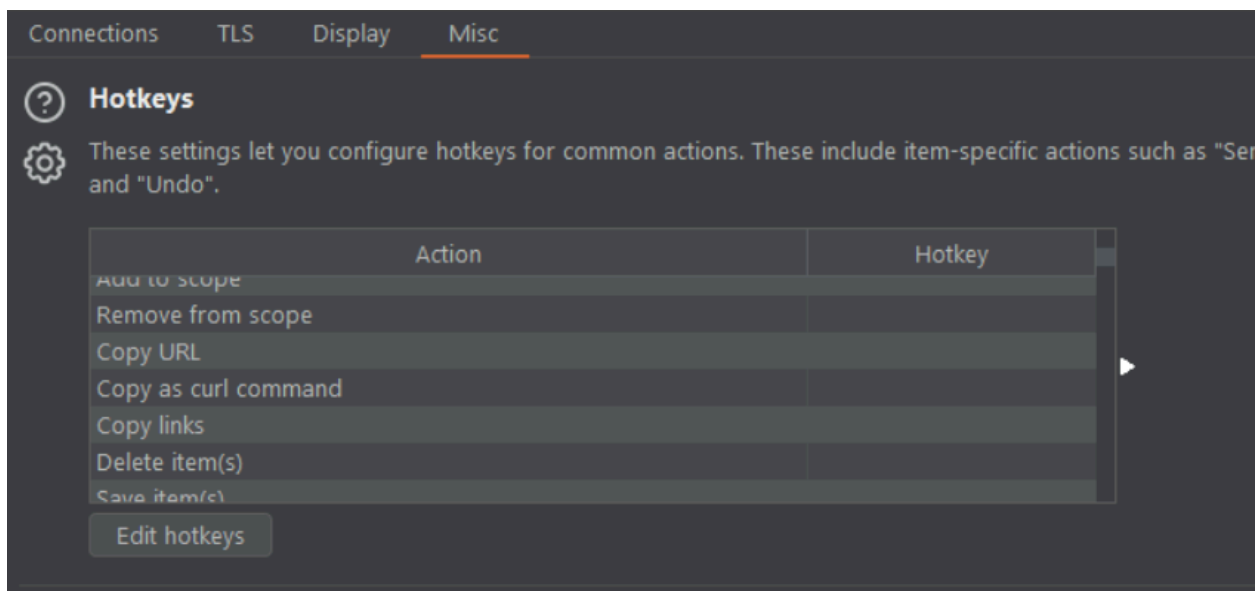
| In which base category can you find the "Updates" sub-category, which controls the Burp Suite update behaviour? Suite



What is the name of the sub-category which allows you to change the keybindings for shortcuts in Burp Suite? Hotkeys

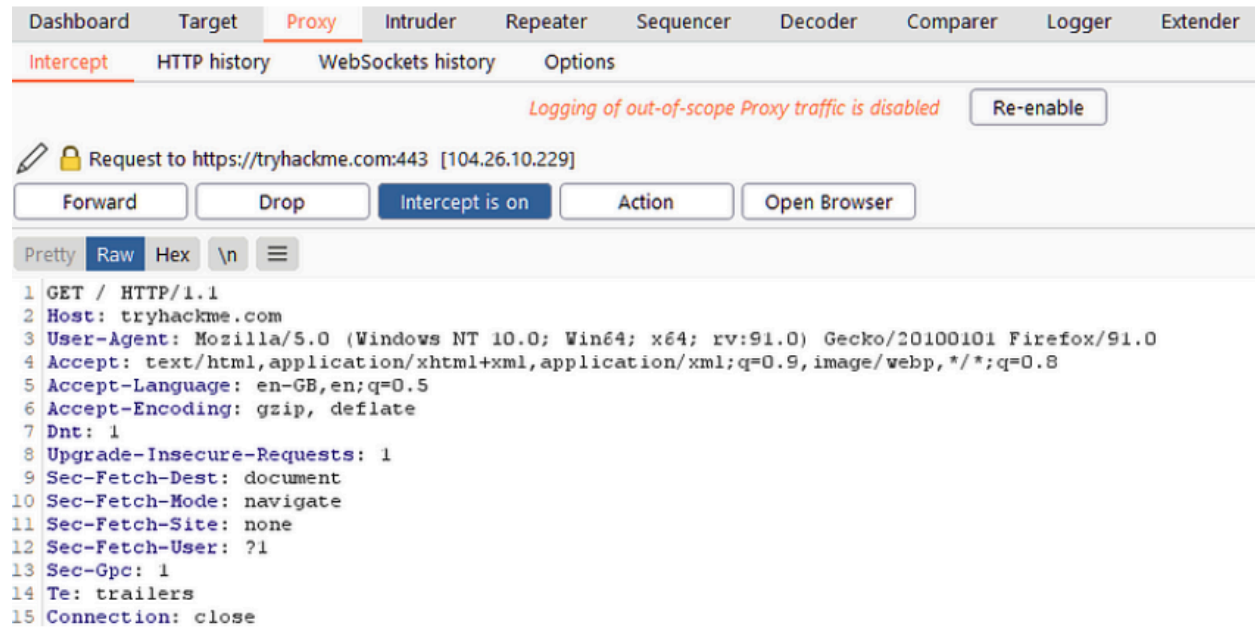


If we have uploaded Client-Side TLS certificates, can we override these on a per-project basis (yea/nay)? yea



Task 8 - Introduction to the Burp Proxy

The Burp Proxy is a fundamental and crucial tool within Burp Suite. It enables the capture of requests and responses between the user and the target web server. This intercepted traffic can be manipulated, sent to other tools for further processing, or explicitly allowed to continue to its destination.



Intercepting Requests: When requests are made through the Burp Proxy, they are intercepted and held back from reaching the target server. The requests appear in the Proxy tab, allowing for further actions such as forwarding, dropping, editing, or sending them to other Burp modules. To disable the intercept and allow requests to pass through the proxy without interruption, click the Intercept is on button.

Taking Control: The ability to intercept requests empowers testers to gain complete control over web traffic, making it invaluable for testing web applications.

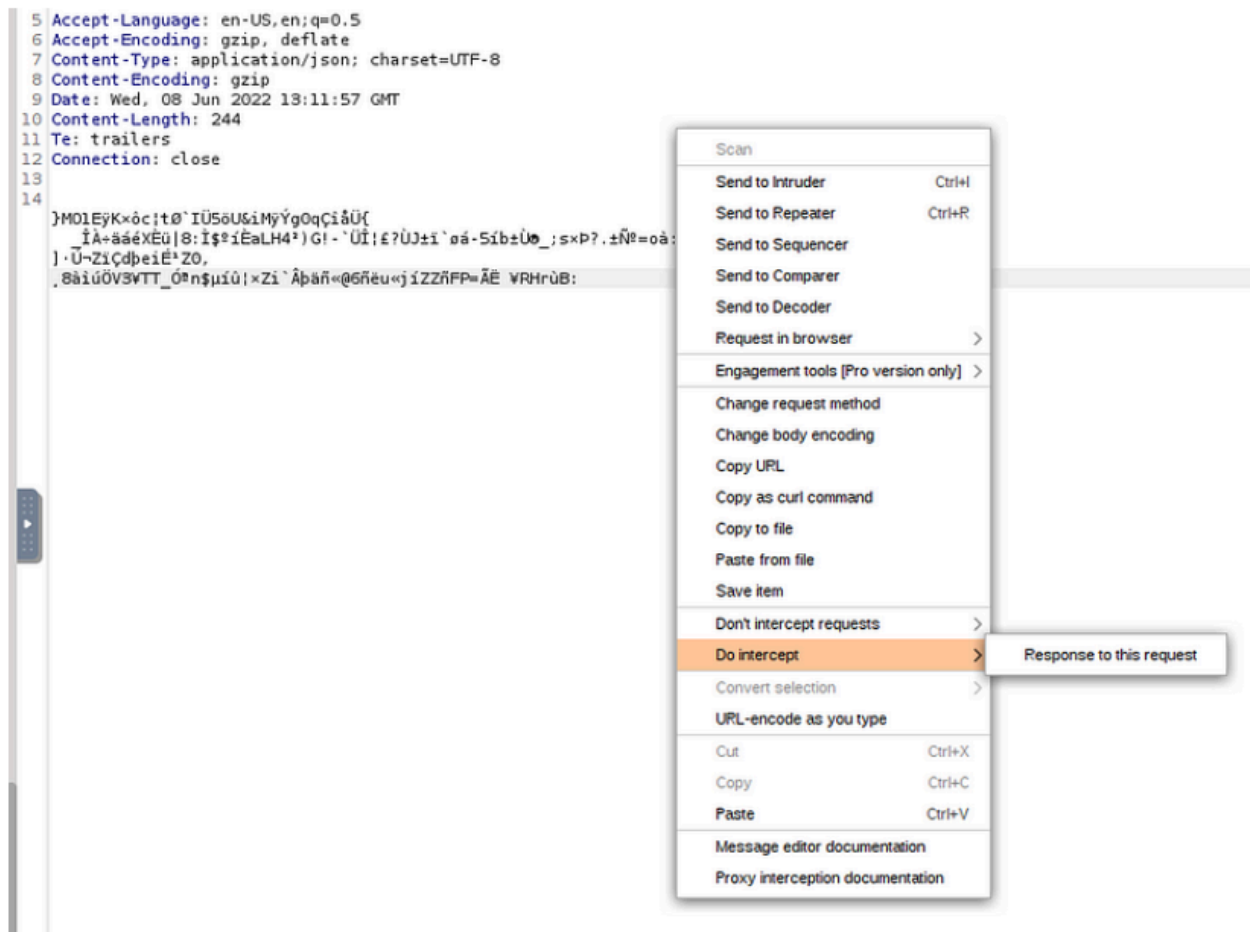
Capture and Logging: Burp Suite captures and logs requests made through the proxy by default, even when the interception is turned off. This logging functionality can be helpful for later analysis and review of prior requests.

WebSocket Support: Burp Suite also captures and logs WebSocket communication, providing additional assistance when analysing web applications.

Logs and History: The captured requests can be viewed in the HTTP history and WebSockets history sub-tabs, allowing for retrospective analysis and sending the requests to other Burp modules as needed.

Task 9 - Connecting through the Proxy (FoxyProxy)

There are two ways to proxy our traffic through Burp Suite. We could use the embedded browser. We can configure our local web browser to proxy our traffic through Burp; this is more common and so will be the focus of this task. The Burp Proxy works by opening a web interface on 127.0.0.1:8080 (by default). As implied by the fact that this is a "proxy", we need to redirect all of our browser traffic through this port before we can start intercepting it with Burp. We can do this by altering our browser settings or, more commonly, by using a Firefox browser extension called FoxyProxy. FoxyProxy allows us to save proxy profiles, meaning we can quickly and easily switch to our "Burp Suite" profile in a matter of clicks, then disable the proxy just as easily.



Finding the **do intercept response to this request** button

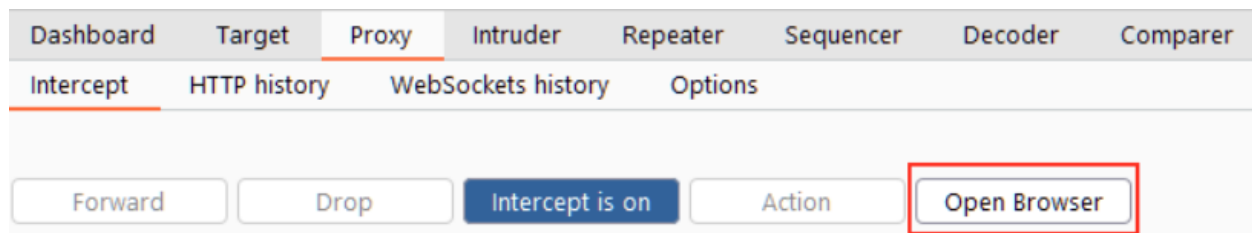
Task 10 - Site Map and Issue Definitions

It consists of three sub-tabs: Site map, Issue definitions, Scope settings.

Task 11 - The Burp Suite Browser

We can start the Burp Browser with the "Open Browser" button in the proxy tab. There are two simple solutions to this:

1. The smart option: We could create a new user and run Burp Suite under a low privilege account.
2. The easy option: We could go to Project options → Misc → Embedded Browser and check the Allow the embedded browser to run without a sandbox option.

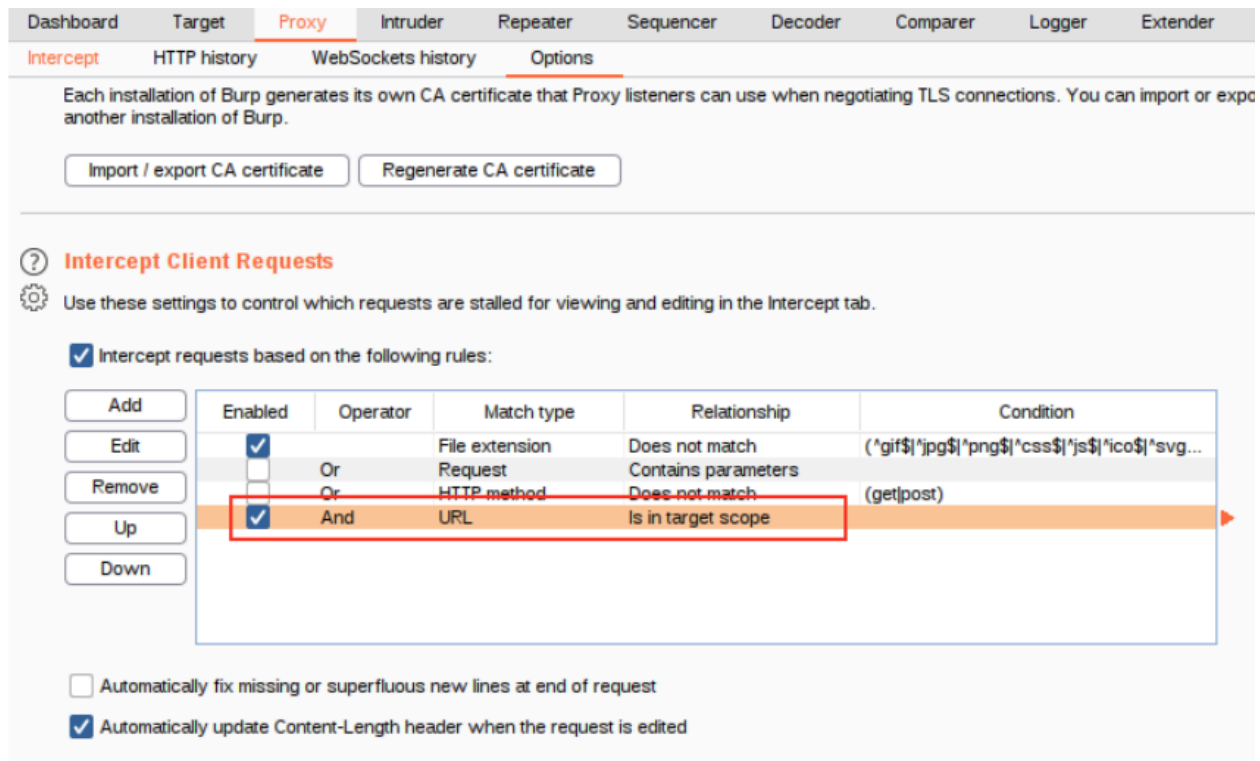


Task 12 - Scoping and Targeting

Scoping can get extremely tedious having Burp capturing all of our traffic. When it logs everything (including traffic to sites we aren't targeting), it muddies up logs we may later wish to send to clients. In short, allowing Burp to capture everything can quickly become a massive pain. Setting a scope for the project allows us to define what gets proxied and logged. The easiest way to do this is by switching over to the "Target" tab, right-clicking our target from our list on the left, then choosing "Add To Scope".

There are three sub-tabs under *Target*:

- **Site map** allows us to map out the apps we are targeting in a tree structure. Every page that we visit will show up here, allowing us to automatically generate a site map for the target simply by browsing around the web app.
- **Scope:** We have already seen the Scope sub-tab — it allows us to control Burp's target scope for the project.
- **Issue Definitions:** Whilst we don't have access to the Burp Suite vulnerability scanner in Burp Community, we do still have access to a list of all the vulnerabilities it looks for. The Issue Definitions section gives us a huge list of web vulnerabilities (complete with descriptions and references).



Adjusting intercept target scope settings

Task 13 - Proxying HTTPS

When intercepting HTTP traffic, you may encounter errors on sites with TLS enabled, such as receiving a message indicating that the PortSwigger Certificate Authority (CA) is not trusted. To resolve this, you need to add the PortSwigger CA certificate to your browser's trusted list. Here's how to do it:

1. Download the CA Certificate:

- With Burp Proxy activated, navigate to `http://burp/cert` to download the `cacert.der` file. Save it on your machine.

2. Access Firefox Certificate Settings:

- Type `about:preferences` in the Firefox URL bar and press Enter.
- Search for "certificates" and click on **View Certificates**.

3. Import the CA Certificate:

- In the **Certificate Manager** window, click **Import** and select the `cacert.der` file you downloaded.

4. Set Trust for the Certificate:

- In the trust settings window, check the box **Trust this CA to identify websites** and click **OK**.

After completing these steps, your browser will trust the PortSwigger CA certificate, allowing you to visit TLS-enabled sites through Burp Suite Proxy without encountering certificate errors.

Task 14 - Example Attack

Here's a step-by-step guide to bypassing this filter and triggering a **Reflected XSS** attack:

1. **Start by ensuring your Burp Proxy is active** and the **intercept** is on.
2. **Submit legitimate data** in the support form. For instance:
 - Email: `pentester@example.thm`
 - Query: `Test Attack`
3. **Intercept the request:** Once you submit the form, Burp Proxy will capture the request.
4. **Modify the request:**
 - Change the email field to your XSS payload: `<script>alert("Succ3ssful XSS")</script>`.
5. **URL encode the payload:** Select the payload and press `Ctrl + U` to URL encode it, ensuring it can be safely sent through the form.
6. **Forward the request:** Press the "Forward" button in Burp Proxy to send the modified request to the server.
7. **Check the result:** If successful, the website should display an alert box indicating that the XSS payload was executed, confirming the vulnerability.

ind items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

Host	Method	URL	Params	Status	Length	MIME type
http://10.10.108.173	GET	/		200	6802	HTML
http://10.10.108.173	GET	/5yjR2GLcoGoi2ZK		200	210	text
http://10.10.108.173	GET	/about/		200	7389	HTML
http://10.10.108.173	GET	/assets/js/bootstrap.bundle...		200	78727	script
http://10.10.108.173	GET	/assets/js/emailFilter.js		200	571	script
http://10.10.108.173	GET	/assets/js/scripts.js		200	601	script
http://10.10.108.173	GET	/products/		200	14372	HTML
http://10.10.108.173	GET	/ticket/		200	4190	HTML
http://10.10.108.173	GET	/about/1				
http://10.10.108.173	GET	/about/2				
http://10.10.108.173	GET	/about/3				
http://10.10.108.173	GET	/about/4				

Request

Response

Pretty

Raw

Hex

Render

```

1 HTTP/1.1 200 OK
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Thu, 09 Jun 2022 19:30:03 GMT
4 Content-Type: text/plain
5 Content-Length: 37
6 Connection: close
7 Front-End-Https: on
8
9 THM{NmNL ZTL iNGE1MWU1ZTQzMzgZnmFiNWVk}

```

Inspector

Request Attributes

2

Request Headers

7

Response Headers

6

Finding the flag in the sitemap

Task 15 - Conclusion

Have a solid foundation in Burp Suite, including the interface, configuration options, and the Burp Proxy. These skills are crucial for your journey into web and mobile application penetration testing. To continue improving, it's a great idea to practice and experiment with Burp Suite. Explore its features, tweak different settings, and familiarize yourself with all the available tools. The more you use Burp Suite, the better you'll become at identifying and exploiting vulnerabilities in web applications.